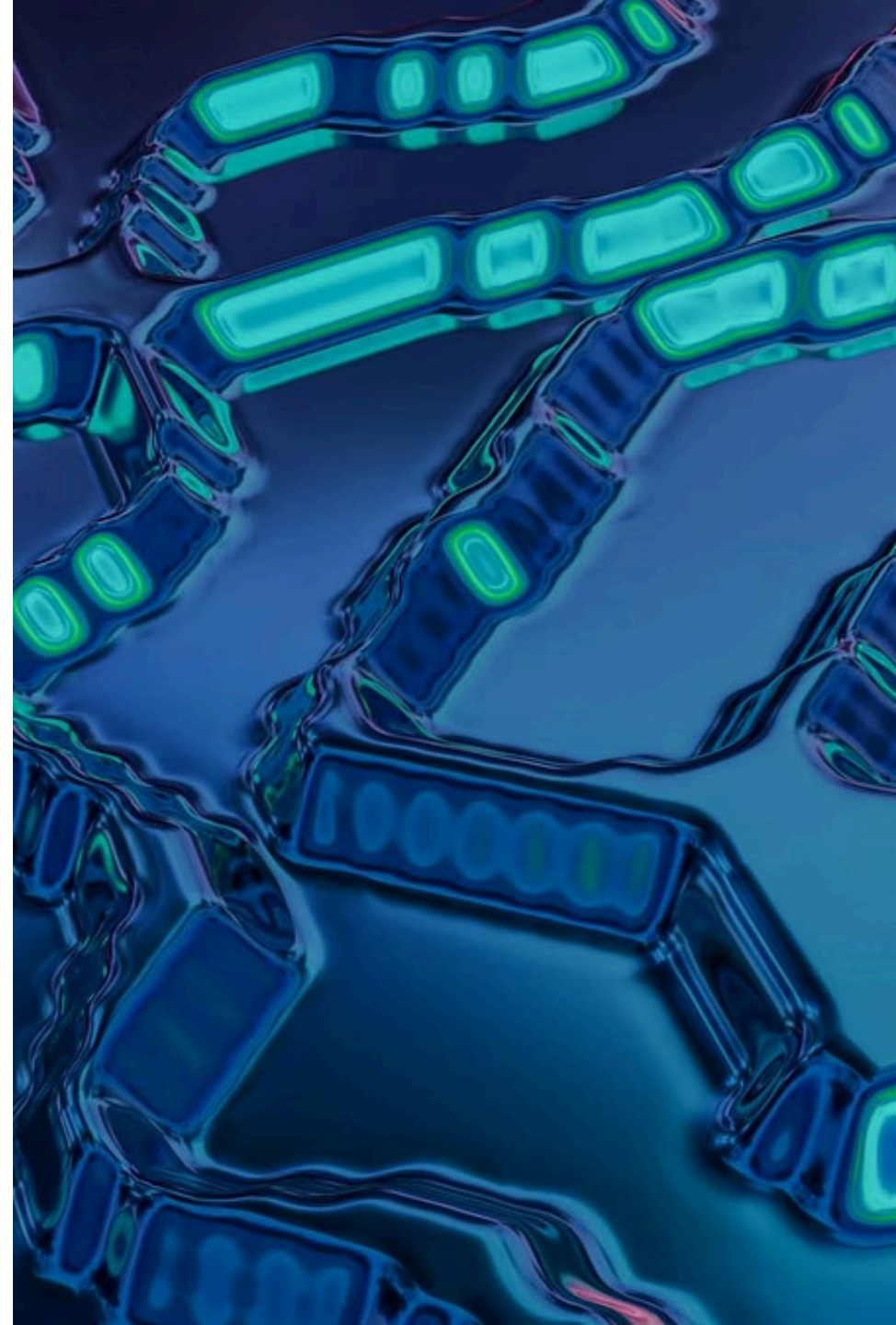


Digital Personal Data Protection (DPDP) Act, 2023

Why Every Organisation Needs to Stay Compliant

INDIA'S LANDMARK DATA PRIVACY LAW



The Digital Privacy Revolution

Every interaction your organisation has with customers, employees, or partners involves personal data. From onboarding forms to marketing campaigns, data flows constantly — and with it comes responsibility.

1.2B+ Internet Users

India is the world's second-largest online population — and growing fast.

Data at Every Touchpoint

Apps, websites, HR systems, and CRMs collect personal data daily — often without clear consent.

Rising Privacy Expectations

Consumers and regulators are demanding greater accountability from every organisation that handles their data.



Why India Introduced the DPDP Act



The Need for a Legal Framework

India's digital economy surpassed \$200B in 2023, yet there was no comprehensive law governing how personal data could be collected, used, or protected. Data misuse, surveillance concerns, and high-profile breaches made legislation urgent.

→ Explosive Digital Growth

UPI, Aadhaar, e-commerce, and fintech generated vast pools of personal data with no unified protection standard.

→ Frequent Data Breaches

India ranked among the top five countries for data breach incidents, exposing millions of citizens.

→ Global Alignment

The DPDP Act aligns India with international frameworks such as GDPR, boosting global business credibility.

What Is Personal Data?

Personal data is any information that can identify an individual — directly or indirectly. The DPDP Act covers a broad spectrum of data types that most organisations already collect.



Identity Data

Name, date of birth, gender, Aadhaar number, PAN card



Contact Data

Email address, phone number, residential address



Financial Data

Bank account details, credit card numbers, transaction history



Health Records

Medical history, prescriptions, insurance details, biometric data



Location & Online Data

IP addresses, cookies, device IDs, browsing history, GPS location

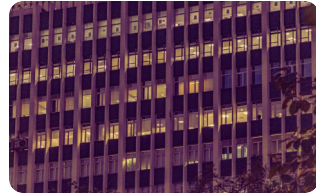
Who Needs to Comply?

If your organisation collects, stores, or processes personal data of Indian residents — **you are covered**, regardless of size or sector.



Startups & SMEs

App-based businesses, SaaS platforms, and early-stage ventures collecting user data



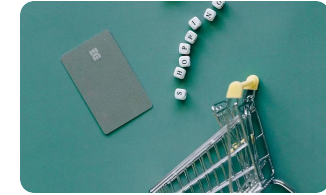
Large Enterprises

Banks, NBFCs, insurers, telecom companies, and IT services firms



Healthcare & Education

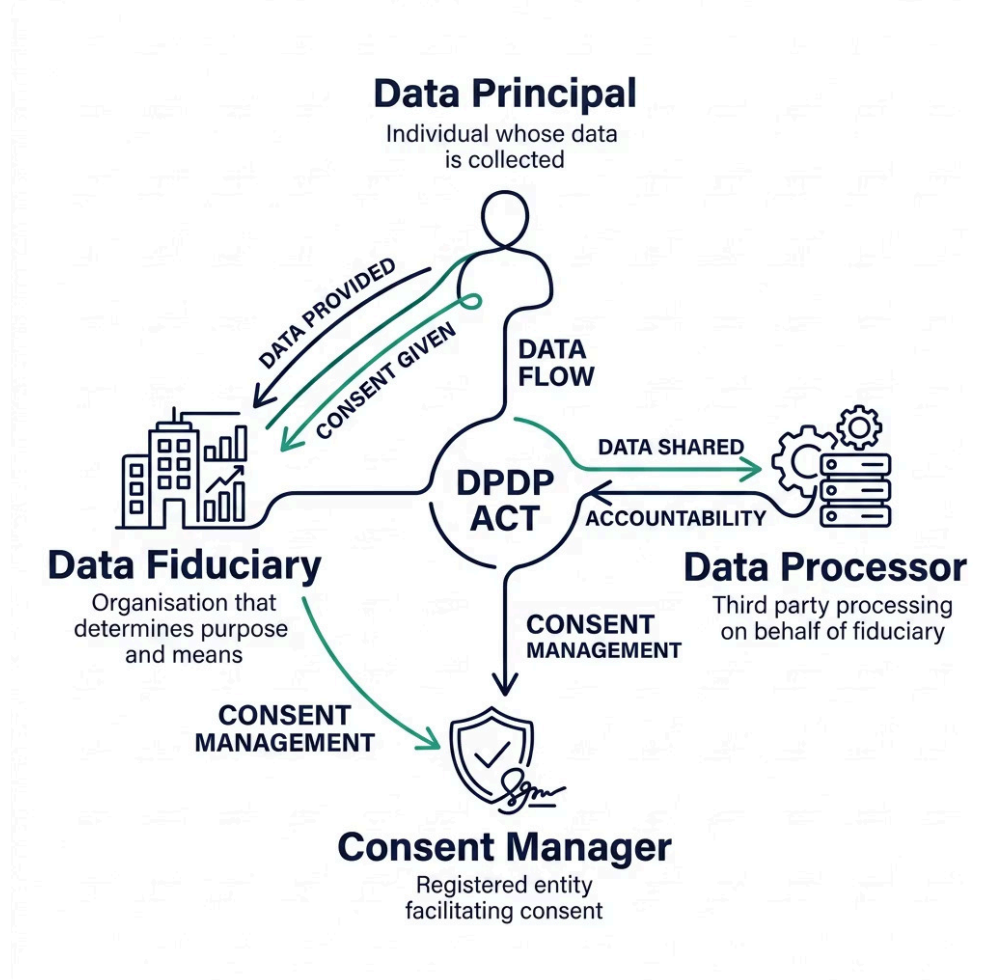
Hospitals, clinics, schools, universities, and edtech platforms



Retail & E-commerce

Online and offline retailers, marketplaces, and loyalty programme operators

Key Stakeholders Under the DPDP Act



Data Principal

The individual (employee, customer, or user) whose personal data is being processed.

Data Fiduciary

Your organisation — the entity that decides why and how data is processed. Bears primary compliance responsibility.

Data Processor

Third-party vendors, cloud providers, or agencies that process data under your instruction.

Consent Manager

A registered intermediary enabling individuals to give, manage, and withdraw consent efficiently.

The Six Core Principles of the DPDP Act



Lawful Consent

Data must be collected only with free, specific, informed, and unambiguous consent.



Purpose Limitation

Data may only be used for the specific purpose for which consent was obtained.



Data Minimisation

Collect only the minimum data necessary — nothing more than what is needed.



Data Accuracy

Ensure personal data is kept accurate, complete, and up to date.



Security Safeguards

Implement appropriate technical and organisational measures to prevent breaches.



Accountability

Fiduciaries must demonstrate compliance and are liable for data processors they engage.

Rights of the Individual (Data Principal)

The DPDP Act empowers every Indian citizen with strong, enforceable rights over their personal data. Organisations must have mechanisms in place to honour each of these rights.

1

Right to Access

Know what data is held about them and how it is being used.

2

Right to Correction

Request updates or corrections to inaccurate or incomplete personal data.

3

Right to Erasure

Request deletion of personal data when it is no longer needed for its purpose.

4

Right to Grievance Redressal

Lodge complaints directly with the Data Fiduciary or the Data Protection Board.

5

Right to Withdraw Consent

Withdraw previously given consent at any time with ease, without facing consequences.

6

Right to Nomination

Nominate another individual to exercise data rights in the event of death or incapacity.

Responsibilities of Organisations



As a Data Fiduciary, your organisation carries significant legal and operational obligations under the DPDP Act. These are not optional — they are enforceable duties.

O1

Publish a Clear Privacy Notice

Before collecting data, inform individuals about what data is collected, why, and how it will be used.

O2

Obtain Valid Consent

Consent must be explicit, specific, freely given — and stored as evidence.

O3

Secure All Processing

Implement encryption, access controls, and security audits to protect personal data.

O4

Notify Breaches Promptly

Report data breaches to the Data Protection Board and affected individuals without delay.

O5

Delete Data When Purpose is Met

Erase personal data once the purpose for processing is fulfilled or upon user request.



The Cost of Non-Compliance

The DPDP Act introduces some of the steepest penalties in Indian regulatory history. Beyond fines, the reputational and operational fallout can be even more damaging.

Up to ₹250 Crore

Penalty for failing to implement adequate security safeguards leading to a data breach.

Up to ₹200 Crore

Penalty for failing to notify the Data Protection Board of a breach in a timely manner.

Up to ₹50 Crore

Penalty for non-compliance with children's data provisions or failure to honour individual rights.

Reputational Damage

Public investigations, media exposure, and loss of customer trust can far outlast any financial penalty.

Real Business Scenarios: Are You at Risk?

Non-compliance is rarely intentional — it often happens through everyday business practices that haven't yet been reviewed against the DPDP Act.



Marketing Without Consent

Sending promotional emails or SMS to individuals who never explicitly opted in — a direct violation.



Employee Data Exposure

HR systems with weak access controls exposing payroll, health, or performance records.



Third-Party Vendor Breaches

A cloud vendor or outsourced processor suffers a breach — your organisation remains liable as the Fiduciary.



Improper Cookie Collection

Websites tracking user behaviour via cookies without a compliant consent banner or opt-out mechanism.

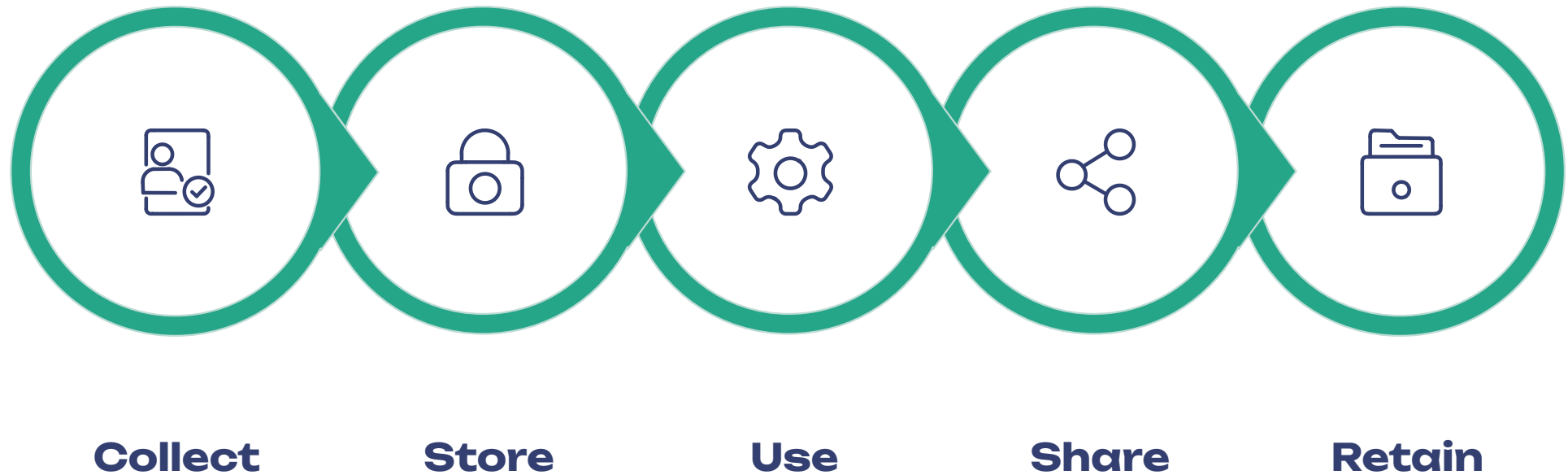


Ignoring Deletion Requests

Failing to act on a customer's erasure request within a reasonable timeframe — actionable by the Board.

The Personal Data Lifecycle

Compliance obligations do not end at the point of collection. Organisations must manage personal data responsibly at every stage of its lifecycle.



At every stage — from collection to deletion — your organisation must be able to demonstrate that data was handled lawfully, securely, and transparently.

DPDP Compliance Checklist



Where to Begin

A structured compliance programme doesn't need to happen overnight. Start with high-impact, low-effort actions and build systematically.

1 Audit Your Data

Map all personal data flows across your organisation — know what you hold, why, and where.

2 Fix Consent Gaps

Review all data collection touchpoints and ensure consent is explicit and documented.

3 Secure Your Systems

Implement or audit encryption, access controls, and breach detection capabilities immediately.

Building a Compliance Programme

Sustainable compliance is built on three interconnected pillars — People, Processes, and Technology. Together, they create a culture of privacy that protects your organisation.



People

Appoint a Data Protection Officer (DPO). Train all employees on data handling. Build a privacy-aware culture from leadership down.



Processes

Establish ROPA (Records of Processing Activities), conduct DPIAs (Data Protection Impact Assessments), define retention policies, and create an incident response playbook.



Technology

Deploy consent management platforms, data discovery tools, encryption solutions, and continuous monitoring dashboards to automate and enforce compliance.



Compliance as a Competitive Advantage

Forward-thinking organisations are discovering that DPDP compliance is not a burden — it is a powerful differentiator that unlocks growth, trust, and enterprise opportunity.



Customer Trust

Consumers are more likely to share data with — and remain loyal to — organisations that visibly respect their privacy.



Enterprise Sales

Large enterprises and global clients increasingly require privacy compliance as a prerequisite for vendor selection.



Risk Reduction

Proactive compliance dramatically reduces exposure to regulatory fines, litigation, and operational disruption.



Global Readiness

DPDP-compliant organisations are better positioned to meet GDPR and other international privacy standards, opening global markets.

Key Takeaways: Act Now

The DPDP Act is Here

This is not a future obligation. It is the law today. Every organisation collecting personal data must begin its compliance journey without delay.

Immediate Compliance

Start obligations now, not later

Organisational Action

Begin your compliance journey

Legal Requirement

Data protection laws apply today

O1

Understand Your Obligations

Know which provisions apply to your organisation, your data types, and your business model.

O2

Start With a Data Audit

Map your personal data landscape — collection points, storage systems, processors, and retention practices.

O3

Build for the Long Term

Invest in people, processes, and technology. Compliance is not a one-time project — it is an ongoing capability.

O4

Treat Privacy as a Value

Organisations that embed privacy into their culture will earn lasting trust, resilience, and a lasting competitive edge.

"Compliance is not just about avoiding penalties — it is about building trust, resilience, and long-term business success."